

7.2 Security Training and Awareness

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
Control Definition Control Objective: Ensure all staff are aware of and fulfil their security responsibilities by performing regular awareness activities, and maintain security knowledge of staff with privileged access. In-scope components: - All staff (such as employees, agents, consultants and contractors) with access to Swift-related systems (as user or for maintenance or administration) - All staff (such as employees, agents, consultants and contractors) with privileged access to Swift-related systems (for maintenance or administration) Risk Drivers: - increased security risk from improperly trained staff						
Implementation Guidance Control Statement: Annual security awareness sessions are conducted for all staff members with access to Swift-related systems. All staff with privileged access maintain knowledge through specific training or learning activities when relevant or appropriate (at management's discretion). Control Context: A security training and awareness programme encourages conscious and appropriate security behaviour of employees and administrators, and generally reinforces good security practice. In addition, it is particularly important that privileged access users have and maintain appropriate knowledge and expertise related to their specific environment or architecture. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). - All staff with access to Swift-related systems complete annual security awareness or training. Topics may include: - Swift-related products and services training (for example, through Swift Smart which is available to all users and has CSP related modules) - Cyber-security threat awareness within the financial services industry or relevant to the staff member's role and responsibilities - Risks related to internet usage or deployment in the cloud - Password security and management - Device security - Safe operating habits (for example, spam and phishing, including "spear³⁹" phishing identification or AI-based (deepfake text, voice and video) phishing, downloading files, browsing practices) - Reporting of suspicious events and activities - Internal or external programme that optionally allows staff to obtain and maintain certification.						

³⁹ Spear phishing is an e-mail or electronic communications scam targeted towards a specific individual, organisation or business.

- In addition, all staff with privileged access maintain their knowledge and expertise in line with their role and responsibilities by considering training or other learning activities that may include topics like:
 - Cyber risks awareness linked to their technologic or Swift-related environment (for example, through IOCs published by Swift) to develop best practice and processes
 - Administering and securing devices and other used systems
 - Detection and response to cyber incidents in line with the organisation's response plan
 - Internal or external programme that optionally allows staff to obtain and maintain certification.
- Training is delivered through the most appropriate channel, including computer-based training, classroom training, and webinars.

Optional Enhancement:

- Social engineering testing, including fake phishing e-mail campaigns, is performed to challenge and enhance security awareness.